

**Федеральное государственное автономное образовательное учреждение высшего
образования**

**«НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ
«ВЫСШАЯ ШКОЛА ЭКОНОМИКИ»**

Московский институт электроники и математики им. Тихонова

Департамент электронной инженерии

Отчет по практике № 4

по курсу «Разработка защищенных программных систем»

Выполнил:

Студент группы МИБИ251

Даниелян Эрик Аргамович

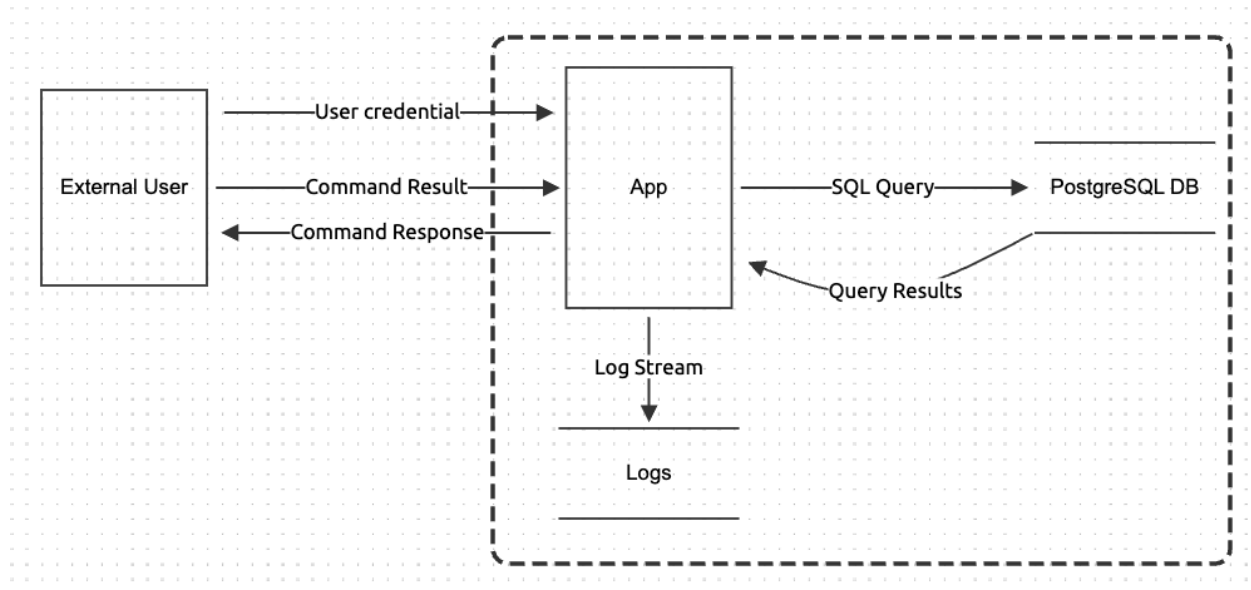
Преподаватель:

ст. преп. Горбунов И.В.

Москва, 2026

Ход работы

1. Диаграмма приложения



2. Угрозы Stride

ID	Элемент DFD	STRIDE	Описание
T1	User Credentials	Spoofing	Нарушитель может подменить учетные данные (shop_user) и получить доступ к приложению, выдавая себя за легитимного пользователя.
T2	User Credentials	Information Disclosure	Логин и пароль могут быть перехвачены при передаче к приложению через незашифрованный или плохо защищённый канал.
T3	Command Result	Information Disclosure	Нарушитель может перехватить ввод пользователя и результаты команд, что позволяет получить конфиденциальные данные из базы (клиенты, товары, заказы).
T4	Command Result	Tampering	Нарушитель может подменять команды или ввод пользователя, изменяя данные в базе без ведома легитимного пользователя.
T5	SQL Query	Tampering	Возможность несанкционированного изменения таблиц через подмену SQL-запросов или пользовательского ввода.
T6	SQL Query	Denial of Service	Перегрузка базы данных большим количеством операций INSERT или длительных транзакций, из-за чего БД становится недоступной.
T7	SQL Query	Elevation of Privilege	Использование широких прав shop_user (GRANT ALL + DEFAULT PRIVILEGES) для выполнения опасных действий в базе (DROP, ALTER и т.п.).
T8	app	Repudiation	Пользователь может отрицать факт входа или выполнения операций, если не ведется полноценный аудит действий.

T9	PostgreSQL DB	Denial of Service	Аварийная остановка базы или исчерпание ресурсов из-за уязвимостей СУБД или чрезмерной нагрузки, что делает БД недоступной.
-----------	---------------	-------------------	---

3. Оценка рисков по DREAD

ID	Угроза	Общая оценка	Уровень риска	Рекомендуемые меры защиты
T6	Denial of Service (SQL Query)	9	Критический	Установка rate limiting запросов, установка query timeout, ограничение количества соединений, WAF, защита от массовых INSERT и тяжёлых транзакций
T9	Tampering (SQL Query)	8.8	Критический	Обязательное использование parameterized queries / Prepared Statements и ORM, минимальные права у пользователя shop_user, строгая валидация и санитизация всех входных данных, регулярный аудит SQL-запросов
T5	Denial of Service (PostgreSQL DB)	8.6	Критический	Мониторинг ресурсов (CPU, RAM, соединения) + alerting, настройка resource limits в postgresql.conf, защита на уровне сети (fail2ban, WAF), своевременные обновления PostgreSQL и ОС, настройка репликации и HA

T3	Information Disclosure (Command Result)	7.8	Высокий	Фильтрация и маскирование чувствительных данных в выводе, использование параметризованных запросов внедрение RBAC/ABAC, запрет вывода конфиденциальной информации в логах и ответах
T4	Tampering (Command Result)	7.8	Высокий	параметризованных запросов / ORM, валидация и санитизация всех пользовательских входов, использование HMAC или цифровых подписей для команд, WAF
T2	Information Disclosure (User Credentials)	7.6	Высокий	Обязательное использование HTTPS/TLS 1.3 для всего трафика, secure + HttpOnly + SameSite cookies, CSP и заголовки безопасности, шифрование чувствительных данных в транзите

T7	Elevation of Privilege (SQL Query)	7.6	Высокий	Принцип наименьших привилегий: убрать GRANT ALL и DEFAULT PRIVILEGES, создать отдельные роли для разных операций, отключить ненужные расширения PostgreSQL, регулярный аудит прав доступа
T1	Spoofing (User Credentials)	7.4	Высокий	Внедрение многофакторной аутентификации (MFA), HTTPS + HSTS, хэширование паролей (bcrypt/Argon2) с солью, rate limiting попыток входа
T8	Repudiation (app)	5.2	Средний	Полноценный аудит всех действий (user_id, IP, timestamp, action), хранение логов в неизменяемом виде, цифровые подписи ключевых операций, централизованный logging

4. Критичные угрозы по ФСТЭК

ID	Угроза	БДУ
T5	Tampering (SQL Query) - несанкционированное изменение таблиц через подмену SQL-запросов	УБИ.3 - Нарушение целостности информации
T6	Denial of Service (SQL Query) -перегрузка БД большим количеством операций INSERT или длительных транзакций	УБИ.6 - Отказ в обслуживании информационных ресурсов
T9	Denial of Service (PostgreSQL DB) - аварийная остановка БД из-за уязвимостей СУБД или чрезмерной нагрузки	УБИ.6 - Отказ в обслуживании информационных ресурсов
T7	Elevation of Privilege (SQL Query) - использование широких прав shop_user для опасных действий	УБИ.1 - Несанкционированный доступ к информационным ресурсам
T1	Spoofing (User Credentials) - подмена учётных данных и доступ от имени легитимного пользователя	УБИ.1 - Несанкционированный доступ к информационным ресурсам